

A Comparative Empirical Study of FIDO2 and Its Predecessors

Anderko Máté
Óbuda University
mate.anderko@stud.uni-obuda.hu

Abstract—The FIDO2 standard, introduced by the FIDO Alliance and the World Wide Web Consortium (W3C) in 2018, it has been hailed as the “Kingslayer of User Authentication”. This paper presents the implementation of a FIDO2 + WebAuthn authentication system and shows an analysis on different user authentication philosophies. The analysis assesses a FIDO2, a 2FA and a password only system on their resistance to common security threats using the STRIDE threat modeling framework and evaluates performance based on latency, memory usage, and computational overhead. The objective is to determine how adopting FIDO2 influences the security, usability, and system resource requirements of information systems.

Index Terms—FIDO2, WebAuthn, Passkeys, Passwordless authentication, Multi-factor authentication, STRIDE, Performance

I. Introduction

Since the dawn of computing the weakest link in most information systems has been the people creating and using them. We choose easy to remember password that might be prone to dictionary attacks, then we overcomplicate them just to forget them, so to only have to remember a couple passwords we reuse them across sites, also we are susceptible to social engineering attacks, like phishing. Sufficiently long, unique, and complex passwords with proper rate limiting remain impractical to brute-force, so compromises overwhelmingly exploit human factors and credential leaks rather than cryptographic weakness. Also the use passwords impose nontrivial support costs and friction because of the resets and account recovery.

To mitigate the weaknesses of a password only environment one-time codes (SMS/TOTP) and push prompts were introduced, this is safety standard is commonly referred to as Multi Factor Authentication MFA materially reduces risk from simple credential stuffing, but common forms remain phishable (e.g., OTP relay, look-alike pages) and are vulnerable to SIM-swap or “push fatigue” attacks. Usability trade-offs (codes, prompts, and device availability) also create drop-off during enrollment and sign-in.

FIDO2/WebAuthn addresses these limitations by replacing shared secrets with origin-bound public-key cryptography and local user verification (biometrics or a device PIN). Private keys never leave the authenticator; the server stores only public keys, eliminating password reuse and greatly reducing the value of stolen databases. Because assertions are tied to the requesting origin, generic

phishing and OTP-relay attacks fail by design. In practice, passkeys (discoverable credentials) further streamline the flow across platforms using platform sync or roaming security keys.

This paper adopts that progression—passwords → MFA → FIDO2—and (i) implements a fully passwordless WebAuthn system, and (ii) compares password-only, password+MFA, and FIDO2 across resilience (phishing, stuffing, brute-force), usability (enrollment, recovery, cross-device), and resource usage (compute, storage, support). We show how MFA mitigates many password risks yet remains phishable, and how FIDO2 offers a principled, practical solution that is both more secure and simpler for end users.

II. Similar and Related Work

This section reviews research on the security, usability, and adoption of FIDO2, also shows a comparison with this here work.

A. Formal and Theoretical Analyses

Barbosa and their team [1] offers a formal model of FIDO2 and, through theoretical analysis, show resistance to credential-phishing and replay attacks. In contrast, the present work examines a deployed FIDO2 stack with STRIDE, emphasizing practical security implications and performance (latency, memory, compute).

B. Empirical and Usability Studies

Lyastani and their team [2] created an empirically FIDO2’s usability analyses. The study shows significant usability gains and phishing resistance compared to passwords and 2FA. Their work relied on user studies and perception metrics rather than system-level measurements.

Unlike these human-centered, behavioral studies, this work isolates the technical performance and security aspects of FIDO2.

C. Positioning of This Work

Key contributions:

- 1) Operational implementation of FIDO2/WebAuthn alongside password-only and 2FA baselines.
- 2) Structured STRIDE analysis, grounded in Barbosa’s theoretical model.

- 3) Empirical performance results—latency, memory footprint, computational load—that complement usability-centric studies (e.g., Lyastani).

Unlike work centered on formal guarantees or user experience, this study examines how adopting FIDO2 shifts real-world security posture and runtime efficiency.

III. Common Authentication Vulnerabilities

Bad actors find the most creative ways to attack authentication systems, these are called attack vectors. The goal of this section is to outline how the vulnerabilities work, which the paper will address in later sections, and also to shine a light on why traditional password or even basic MFA schemes struggle against them.

A. Weak Passwords and Brute-Force Attacks

Users often choose simple passwords, making them easy targets for brute-force attacks [3]. A simple brute force attack tries to crack the user’s password by trying random character combinations. Rate limiting and sufficient password length makes the attack redundant. A dictionary attack is a more sophisticated version of a brute force attack, where attackers use common wordlists, lists of frequently used passwords or they systematically guess combinations to find the password. In the case of brute force not cryptographic weaknesses, but bad password hygiene and the site’s lack of password complexity enforcement leads to the compromise.

B. Credential Stuffing and Password Reuse

Credential stuffing exploits password reuse across websites. In the event of a databreach the user’s password may get leaked, this creates an opportunity for bad actors, who then use the credentials on other sites to try to gain access to other accounts.[4]. The process can be well automated, thus the reuse of credentials turns one breach into many.

C. Social Engineering Attacks

Many attacks rely on human gullability instead of technical flaws. Phishing, SIM swap, and push fatigue attacks are such attacks.

- 1) Phishing and OTP Relay: Phishing deceives users into revealing credentials on fake websites, that mimic the working of the site the user is familiar with. Attackers can proxy the login and capture OTP codes in real time, bypassing traditional 2FA, this is commonly referred to as a real-time phishing proxy. OTP capturing is Adversary-in-the-Middle type attack[5].

- 2) SIM Swap Attacks: The way SMS based MFA works is that the user gets an SMS containing a secret code, generated by the server, this while may seems bulletproof requires complete trust in the user’s telecommunication service provider. The attackers may be able to impersonate victims and hijack their phone number (with the service provider unknowingly complicit), thus gaining control of SMS-based OTPs[6].

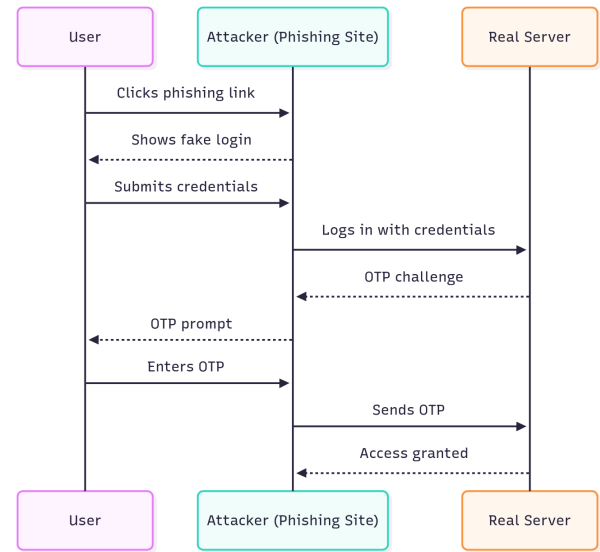


Fig. 1. Phishing with OTP relay

- 3) MFA Push Fatigue: Push-based MFA can be exploited by flooding users with repeated prompts until they approve one, often by mistake or frustration [7].

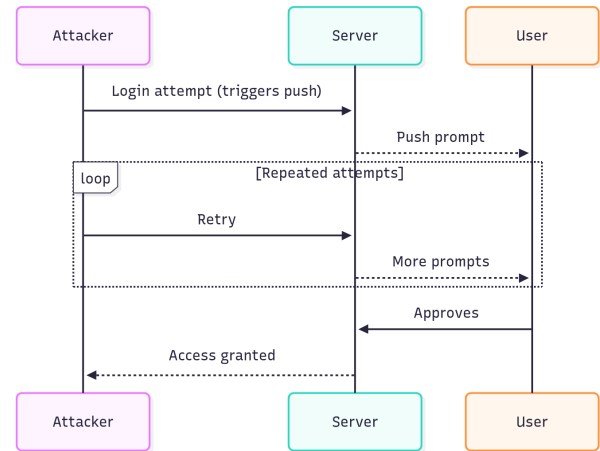


Fig. 2. Push fatigue attack sequence

IV. How FIDO2 Works

V. STRIDE Threat Modelling Framework

VI. Implementation

VII. Performance Testing

References

- [1] M. Barbosa et al., “Provable security analysis of fido2,” in Information Security Theory and Practice (WISTP 2021). Springer, 2021. [Online]. Available: https://dl.acm.org/doi/10.1007/978-3-030-84252-9_5

- [2] S. Lyastani et al., “Is fido2 the kingslayer of user authentication?” in IEEE Symposium on Security and Privacy, 2020. [Online]. Available: <https://trust.cispa.saarland/publication/lyastani-20-sp/lyastani-20-sp.pdf>
- [3] E. Ma, S. Hasama, E. Lumba, and E. Birrell, “Prospects for improving password selection,” arXiv preprint arXiv:2201.01350, 2022.
- [4] A. Nisenoff, M. Golla, M. Wei, J. Hainline, H. Szymanek, A. Braun, A. Hildebrandt, B. Christensen, D. Langenberg, and B. Ur, “A two-decade retrospective analysis of a university’s vulnerability to attacks exploiting reused passwords,” in Proc. USENIX Security Symposium, 2023.
- [5] M. Käsemodel, V. Winterhalter, F. Heisel, F. Alt, and B. Pfleging, “BlueTOTP: Designing phishing-resistant and user-friendly two-factor authentication,” in Proc. IFIP INTERACT 2025 (LNCS 16110). Springer, 2025, pp. 611–634.
- [6] K. Lee, B. Kaiser, J. Mayer, and A. Narayanan, “An empirical study of wireless carrier authentication for SIM swaps,” in Proc. 16th Symposium on Usable Privacy and Security (SOUPS). USENIX Association, 2020, pp. 61–79.
- [7] Cybersecurity & Infrastructure Security Agency (CISA), “Implementing phishing-resistant mfa (fact sheet),” <https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa.pdf>, 2022, accessed 2025-10-29.